

# ICT3216

## Introduction to Ethical Hacking

### Group Assignment 01

| Name                  | Registration No. | Index No. |
|-----------------------|------------------|-----------|
| S.R.D.M.S.Mahindasena | ICT/2021/068     | 5227      |
| K.A.D.Senadi          | ICT/2021/109     | 5264      |
| S.N.Mapitigama        | ICT/2021/069     | 5228      |
| T.L.Kumarasiri        | ICT/2021/150     | 5303      |



Department of Computing  
Faculty of Applied Sciences  
Rajarata University of Sri Lanka

17<sup>th</sup> February 2026

## 1. Introduction

Reconnaissance is the initial step in ethical hacking and penetration testing. It is the procedure of gathering data on the target system, network, or application. Reconnaissance is used to determine open ports, running services, server settings, and technologies employed in web applications.

For this assignment, reconnaissance methods were executed on a real-world target that was chosen from a bug bounty platform. The chosen platform was Bugcrowd, and the target selected was Luno ([www.luno.com](http://www.luno.com)). Luno is a globally recognized cryptocurrency exchange platform operating across Africa, Europe, and Southeast Asia, serving over 10 million users. The primary tools employed in this assignment were Nmap, Nmap NSE scripts, and Wappalyzer. All the activities were done in an ethical manner, as per the scope and rules of the bug bounty platform.

## 2. Target Overview

### 2.1 Selected Bug Bounty Program

The chosen bug bounty program was the Luno program listed on Bugcrowd. Luno is a leading cryptocurrency exchange that enables users to buy, sell, store, and learn about cryptocurrencies such as Bitcoin and Ethereum.

Before carrying out the reconnaissance, it was important to read the program policy and scope. Only the assets that were in-scope were chosen to be tested.

**Mobile targets** ✓ In scope

P1 \$4500 – \$7500

P2 \$2250 – \$3000

P3 \$825 – \$1000

P4 \$225 – \$375

Staging mobile apps are not currently available. Mobile apps are in production. Integrity and stability testing are out of scope. Please see the [out of scope](#) and [excluded submission types](#) section for further details.

 Luno Android Application

Java Kotlin Android

1



 Luno iOS Application

Swift iOS

2



 <https://mobileapi.staging.luno.com/>

API Testing Mobile Application Testing

0



**Web targets** ✓ In scope

P1 \$2500 – \$3000

P2 \$1500 – \$1800

P3 \$500 – \$650

P4 \$100 – \$200

*Bugcrowd – Luno Bug Bounty Program Scope Page*



### 3. Task 1: Nmap Port Scan

#### 3.1 Tool Used

- Nmap (Network Mapper)

#### 3.2 Finding the IP Address

To identify the IP address of the domain, the following command was used:

```
nslookup www.luno.com
```

The output provided the IP addresses associated with the domain. Multiple addresses were returned, confirming that Luno uses a distributed infrastructure through Cloudflare.

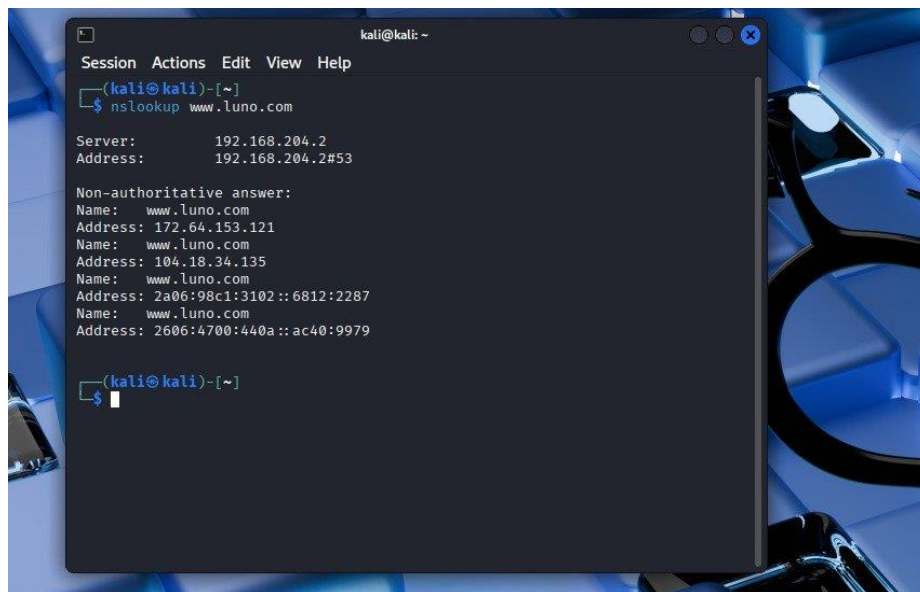


Figure 1: nslookup output revealing IP addresses of www.luno.com

#### 3.3 Nmap Scan Command

The following command was used to perform the port scan:

```
nmap -sV -Pn www.luno.com
```

Explanation:

- -sV detects service and version information on open ports
- -Pn disables host discovery (ping) — treats the host as online
- www.luno.com is the target domain

#### 3.4 Results

The Nmap scan revealed the open ports and running services on the target. All open ports were routed through Cloudflare's proxy infrastructure.

```

kali@kali: ~
Session Actions Edit View Help
Address: 2606:4700:440a::ac40:9979

(kali@kali)-[~]
$ nmap -sV -Pn www.luno.com
zsh: bad pattern: ^[[200~nmap

(kali@kali)-[~]
$ nmap -sV -Pn www.luno.com

Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-16 22:00 EST
Nmap scan report for www.luno.com (104.18.34.135)
Host is up (0.092s latency).
Other addresses for www.luno.com (not scanned): 172.64.153.121 2606:4700:440a::ac40:9979 2a06:98c1:3102::6812:2287
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http   Cloudflare http proxy
443/tcp    open  ssl/http Cloudflare http proxy
8080/tcp   open  http   Cloudflare http proxy
8443/tcp   open  ssl/http Cloudflare http proxy

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 48.64 seconds

(kali@kali)-[~]
$

```

Figure 2: Nmap port scan results for www.luno.com

### 3.5 Open Ports Table

| Port     | State | Service   | Version / Details     |
|----------|-------|-----------|-----------------------|
| 80/tcp   | Open  | HTTP      | Cloudflare HTTP Proxy |
| 443/tcp  | Open  | SSL/HTTPS | Cloudflare HTTP Proxy |
| 8080/tcp | Open  | HTTP-Alt  | Cloudflare HTTP Proxy |
| 8443/tcp | Open  | SSL-Alt   | Cloudflare HTTP Proxy |

### 3.6 Observations

The scan results show that the target web application is accessible through HTTP and HTTPS services. All detected open ports route through Cloudflare's proxy, confirming the use of a CDN and DDoS protection layer. The presence of HTTPS indicates encrypted communication is enforced, which is important for protecting user data. The 996 filtered ports suggest that Cloudflare's firewall actively blocks all non-essential ports, significantly reducing the attack surface. The origin server's real IP address is hidden behind Cloudflare, which is a strong defensive security measure.

## 4. Task 2: Nmap NSE Script Scan

### 4.1 Script Selected

The following NSE script was selected:

- ssl-enum-ciphers

This script is used to identify the supported SSL/TLS protocol versions and cipher suites on a target. It was selected because Luno is a financial platform handling real cryptocurrency transactions, making strong SSL/TLS configuration critically important to prevent man-in-the-middle attacks and data interception.

## 4.2 Command Used

```
nmap --script ssl-enum-ciphers -p 443 www.luno.com
```

Explanation:

- `--script ssl-enum-ciphers` runs the SSL/TLS cipher suite enumeration script
- `-p 443` specifies the HTTPS port
- `www.luno.com` is the target domain

## 4.3 Results

The scan output displayed the supported encryption protocols and cipher suites used by luno.com. Strong cipher suites improve security and prevent attackers from breaking or intercepting encrypted communications.

```
kali@kali: ~  
Session Actions Edit View Help  
Nmap done: 1 IP address (1 host up) scanned in 48.64 seconds  
  
(kali@kali)-[~]  
$ nmap --script ssl-enum-ciphers -p 443 www.luno.com  
  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-16 22:03 EST  
Nmap scan report for www.luno.com (104.18.34.135)  
Host is up (0.0064s latency).  
Other addresses for www.luno.com (not scanned): 172.64.153.121 2606:4700:440a::ac40:9979 2a0  
6:98c1:3102::6812:2287  
  
PORT      STATE SERVICE  
443/tcp   open  https  
| ssl-enum-ciphers:  
|   TLSv1.2:  
|   | ciphers:  
|   | | TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (ecd_h_x25519) - A  
|   | | TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (ecd_h_x25519) - A  
|   | | TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (ecd_h_x25519) - A  
|   | | TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (ecd_h_x25519) - A  
|   | | TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (ecd_h_x25519) - A  
|   | compressors:  
|   | | NULL  
|   | cipher preference: server  
|   | TLSv1.3:  
|   | | ciphers:  
|   | | | TLS_AKE_WITH_AES_128_GCM_SHA256 (ecd_h_x25519) - A  
|   | | | TLS_AKE_WITH_AES_256_GCM_SHA384 (ecd_h_x25519) - A  
|   | | | TLS_AKE_WITH_CHACHA20_POLY1305_SHA256 (ecd_h_x25519) - A  
|   | | cipher preference: client  
|   | | _ least strength: A  
|  
Nmap done: 1 IP address (1 host up) scanned in 4.07 seconds  
  
(kali@kali)-[~]  
$
```

Figure 3: Nmap `ssl-enum-ciphers` NSE script output for `www.luno.com`

## 4.4 Observations

The results indicate that Luno maintains a strong SSL/TLS configuration. The following key observations were made:

- Both TLS 1.2 and TLS 1.3 are supported — the two most current and secure protocol versions available.
- All detected cipher suites received an "A" grade, indicating excellent encryption configuration.
- ECDHE (Elliptic Curve Diffie-Hellman Ephemeral) key exchange is used, providing Perfect Forward Secrecy (PFS). This means that even if the server's private key is compromised in the future, past session data remains secure.
- ChaCha20-Poly1305 cipher suites are included, providing high-performance encryption particularly beneficial for mobile users.
- No weak cipher suites such as RC4, DES, or 3DES were detected.

- No outdated protocols such as SSLv3, TLS 1.0, or TLS 1.1 were present.
- Overall least strength grade: A — Luno maintains excellent SSL/TLS security standards.

## 5. Task 3: Identify Technologies in Use (Using Wappalyzer)

### 5.1 Tool Used

- Wappalyzer (Browser Extension)

### 5.2 Procedure

The following steps were followed:

1. Opened the web application <https://www.luno.com> in the Firefox browser on Kali Linux.
2. Opened the Wappalyzer browser extension by clicking its icon in the toolbar.
3. Identified all technologies detected by Wappalyzer across all categories.
4. Documented results and captured screenshots.

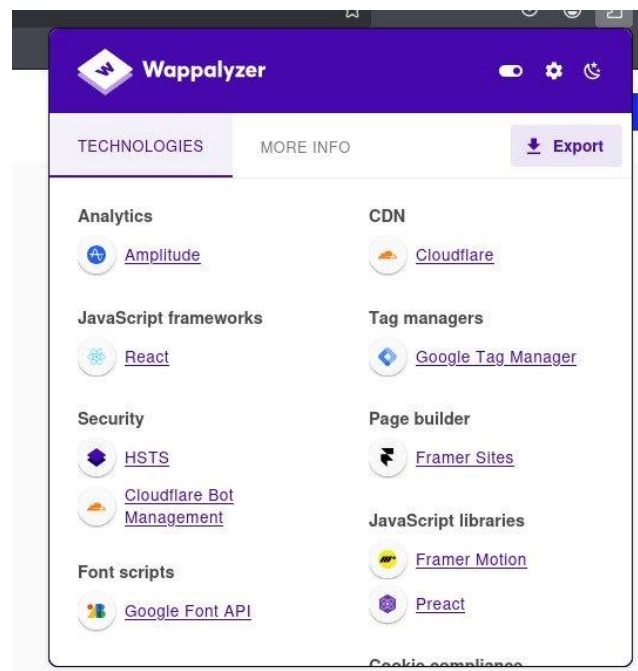


Figure 4: Wappalyzer technology detection — Part 1

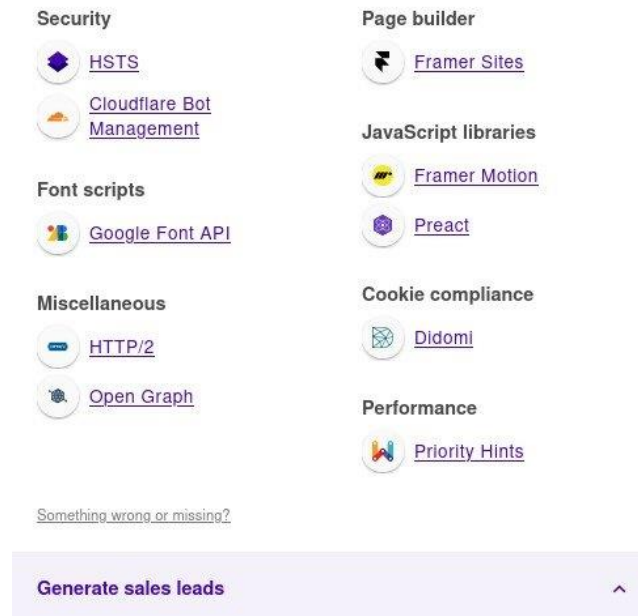


Figure 5: Wappalyzer technology detection — Part 2

## 5.3 Technology Findings

### 1. JavaScript Framework

- React

### 2. Content Delivery Network (CDN) and Security

- Cloudflare
- Cloudflare Bot Management

### 3. Security

- HSTS (HTTP Strict Transport Security)

### 4. Page Builder

- Framer Sites

### 5. JavaScript Libraries

- Framer Motion
- Preact

### 6. Tag Manager

- Google Tag Manager

### 7. Analytics

- Amplitude

### 8. Cookie Compliance

- Didomi

### 9. Miscellaneous Technologies

- HTTP/2
- Open Graph
- Priority Hints
- Google Font API

## 6. Task 4: Research Common Vulnerabilities

Based on the technologies identified in Task 3, recent and critical vulnerabilities related to those frameworks and libraries were researched. The research was conducted using the National Vulnerability Database (NVD) and published security advisories. Note: luno.com does not need to be actively vulnerable to these specific issues — the assignment requires research based on the detected technology stack.

### Vulnerability 1: Remote Code Execution in React Server Components

**Technology:** React

**CVE ID:** CVE-2025-55182

**Severity:** Critical (CVSS Score: 10.0 / 10.0)

#### Description

A critical Remote Code Execution (RCE) vulnerability, referred to as "React2Shell," was discovered in React Server Components (RSC). An unauthenticated attacker can send a specially crafted HTTP request to any Server Function endpoint. When this request is deserialized by React, it allows the attacker to execute arbitrary code on the server. This vulnerability stems from an unsafe deserialization flaw in the RSC Flight data-handling logic. Active exploitation was observed within hours of public disclosure.

#### Impact

- Complete server compromise and full loss of control over the platform
- Unauthorized access to user wallet data and private cryptographic keys
- Theft of authentication tokens and user session data
- Potential for unauthorized fund transfers

#### Remediation

- Immediately upgrade React to version 19.0.1, 19.1.2, or 19.2.1
- Update all RSC-related packages (react-server-dom-\*)
- Enable Cloudflare WAF rules specifically targeting CVE-2025-55182
- Implement strict input validation on all Server Function endpoints

## 🚩 CVE-2025-55182 Detail

### Description

A pre-authentication remote code execution vulnerability exists in React Server Components versions 19.0.0, 19.1.0, 19.1.1, and 19.2.0 including the following packages: `react-server-dom-parcel`, `react-server-dom-turbopack`, and `react-server-dom-webpack`. The vulnerable code unsafely deserializes payloads from HTTP requests to Server Function endpoints.

## Metrics

|                  |                         |                  |
|------------------|-------------------------|------------------|
| CVSS Version 4.0 | <b>CVSS Version 3.x</b> | CVSS Version 2.0 |
|------------------|-------------------------|------------------|

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

**CVSS 3.x Severity and Vector Strings:**



**NIST: NVD**

Base Score: N/A

NVD assessment not yet provided.



**CNA:** Facebook, Inc.

**Base Score:** 10.0 CRITICAL

**Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

## QUICK INFO

**CVE Dictionary Entry:**

CVE-2025-55182

**NVD Published Date:**

12/03/2025

**NVD Last Modified:**

12/09/2025

**Source:**

Facebook, Inc.

NVD CVE-2025-55182 Detail Page

## Vulnerability 2: Denial of Service via Infinite Loop in React

### Technology: React

**CVE ID:** CVE-2025-55184

**Severity:** High (CVSS Score: 7.5 / 10.0)

## Description

A Denial of Service (DoS) vulnerability exists in React Server Components. A maliciously crafted HTTP request sent to any Server Functions endpoint can cause an infinite loop when deserialized by React, making the server completely unresponsive until it is manually restarted. This vulnerability was discovered during follow-up research after the React2Shell (CVE-2025-55182) critical vulnerability disclosure.

## Impact

- Complete platform unavailability, preventing users from accessing accounts or trading
- Time-sensitive cryptocurrency transactions blocked during an attack
- Significant financial losses for users during volatile market periods

## Remediation

- Upgrade React to the latest patched versions (19.0.4+, 19.1.5+, or 19.2.4+)
- Implement server-side request timeout and rate limiting
- Set up automated monitoring and server restart policies

## CVE-2025-55184 Detail

### MODIFIED

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

### Description

A pre-authentication denial of service vulnerability exists in React Server Components versions 19.0.0, 19.0.1 19.1.0, 19.1.1, 19.1.2, 19.2.0 and 19.2.1, including the following packages: react-server-dom-parcel, react-server-dom-turbopack, and react-server-dom-webpack. The vulnerable code unsafely deserializes payloads from HTTP requests to Server Function endpoints, which can cause an infinite loop that hangs the server process and may prevent future HTTP requests from being served.

### QUICK INFO

#### CVE Dictionary Entry:

CVE-2025-55184

#### NVD Published Date:

12/11/2025

#### NVD Last Modified:

12/15/2025

#### Source:

Facebook, Inc.

### Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

#### CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: N/A

NVD assessment not yet provided.



CNA: Facebook, Inc.

Base Score: 7.5 HIGH

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

*NVD\_CVE-2025-55184 Detail Page*

## Vulnerability 3: Cloudflare Reverse-Proxy Trust Bypass

**Technology:** Cloudflare / Cloudflare Bot Management

**CVE ID:** N/A (Published Security Research — Certitude, 2023)

**Severity:** High (Estimated CVSS: ~7.5)

### Description

Security researchers identified a vulnerability in how Cloudflare's shared infrastructure handles trust between its reverse-proxy servers and customer origin servers. Because origin servers trust traffic arriving from Cloudflare's IP ranges, attackers discovered that creating a free Cloudflare account and routing malicious traffic through Cloudflare's own servers makes attack traffic appear to come from trusted Cloudflare IPs. This effectively bypasses the target's IP allowlist and all WAF rules, delivering malicious requests directly to the origin server while circumventing all Cloudflare protections.

### Impact

- DDoS attacks can bypass Cloudflare protection and reach origin servers unfiltered
- Bot-driven credential stuffing and brute-force attacks on user accounts become possible
- WAF rules protecting against SQL injection, XSS, and other attacks are bypassed

### Remediation

- Enable Cloudflare's Authenticated Origin Pulls feature to verify that traffic truly originates from Cloudflare
- Configure a shared secret token between Cloudflare and the origin server for verification
- Never rely solely on IP-based allowlisting as the only trust mechanism

## Vulnerability 4: HTTP/2 Rapid Reset Denial of Service Attack

**Technology:** HTTP/2 (detected via Wappalyzer)

**CVE ID:** CVE-2023-44487

**Severity:** High (CVSS Score: 7.5 / 10.0)

### Description

A fundamental flaw in the HTTP/2 protocol allows attackers to perform a "Rapid Reset" attack by sending thousands of HTTP/2 stream requests and immediately cancelling each one per second. The

server must process each request before the cancellation is received, generating massive computational load with minimal attacker effort. This vulnerability was used in the largest DDoS attack ever recorded (October 2023), peaking at 398 million requests per second. Luno uses HTTP/2, confirmed by Wappalyzer during Task 3.

## Impact

- Complete platform shutdown, preventing all users from trading or accessing wallets
- Direct financial harm to users unable to execute time-critical transactions
- Reputational damage and potential regulatory implications for the platform

## Remediation

- Ensure Cloudflare's DDoS protection is fully configured and active
- Configure HTTP/2 connection and stream limits at the server level
- Implement real-time traffic monitoring and automated incident response

The screenshot displays the NIST National Vulnerability Database (NVD) detail page for CVE-2023-44487. The page header includes the NIST logo and 'NATIONAL VULNERABILITY DATABASE'. A green 'VULNERABILITIES' button is visible. The main section is titled 'CVE-2023-44487 Detail' with a 'Description' subsection. The description states: 'The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.' Below the description is a 'Metrics' section showing CVSS scores for Version 4.0, Version 3.x (7.5 HIGH), and Version 2.0. A 'QUICK INFO' sidebar on the right provides additional details: 'CVE Dictionary Entry: CVE-2023-44487', 'NVD Published Date: 10/10/2023', 'NVD Last Modified: 11/07/2025', and 'Source: MITRE'.

*NVD\_CVE-2023-44487 Detail Page*

## Summary of Vulnerabilities

| CVE(s)         | Vulnerability           | Technology           | CVSS | Severity |
|----------------|-------------------------|----------------------|------|----------|
| CVE-2025-55182 | Remote Code Execution   | React                | 10.0 | CRITICAL |
| CVE-2025-55184 | Denial of Service       | React                | 7.5  | HIGH     |
| N/A            | Reverse-Proxy Bypass    | Cloudflare Bot Mgmt. | ~7.5 | HIGH     |
| CVE-2023-44487 | HTTP/2 Rapid Reset DDoS | HTTP/2               | 7.5  | HIGH     |

## 7. Conclusion and Recommendations

### 7.1 Conclusion

This assignment provided hands-on experience in performing reconnaissance on a real-world web application listed under a bug bounty platform. Nmap scans successfully identified open ports and

services, confirming that luno.com is protected by Cloudflare's proxy infrastructure with only essential web ports exposed. NSE scripts provided deeper insight into SSL/TLS configurations, revealing that Luno maintains an excellent "A" grade cipher suite configuration with support for TLS 1.2 and TLS 1.3. Wappalyzer identified the technology stack employed by the website, including React, Cloudflare Bot Management, and HTTP/2.

Reconnaissance is essential in ethical hacking because it helps security professionals understand the target environment and identify possible attack surfaces before conducting further testing. The findings from this assignment demonstrate that while Luno maintains strong infrastructure-level security, the technologies in use — particularly React Server Components — carry associated vulnerabilities that warrant urgent attention.

## 7.2 Key Recommendations

Based on the reconnaissance results, the following recommendations are suggested:

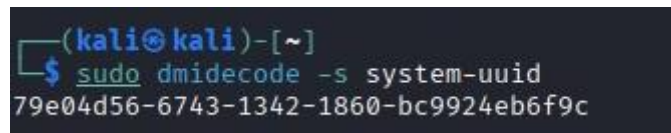
- Immediately upgrade React to the latest patched version to address the critical CVE-2025-55182 Remote Code Execution vulnerability (CVSS 10.0).
- Enable Cloudflare Authenticated Origin Pulls to prevent the reverse-proxy trust bypass attack.
- Configure HTTP/2 connection limits and rate limiting to reduce exposure to Rapid Reset DDoS attacks.
- Implement Web Application Firewall (WAF) custom rules targeting React Server Component endpoints.
- Perform regular automated dependency auditing using tools such as npm audit and Dependabot.
- Apply defence-in-depth security — application-level controls should not depend solely on the CDN/WAF layer.
- Subscribe to security advisories for all technologies in use and patch promptly.

## 8. Proof of Independent Work — System UUID

As required by the assignment, the following screenshots show the output of the `sudo dmidecode -s system-uuid` command from each team member's individual Kali Linux virtual machine, verifying that the work was completed independently.

```
sudo dmidecode -s system-uuid
```

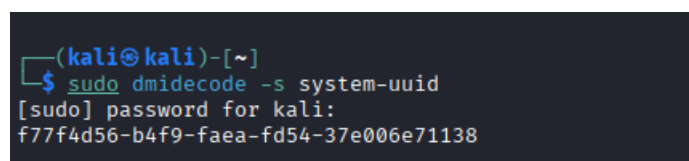
### Team Member 1 — S.R.D.M.S.Mahindasena (ICT/2021/068)



```
(kali@kali)-[~]  
$ sudo dmidecode -s system-uuid  
79e04d56-6743-1342-1860-bc9924eb6f9c
```

*Kali VM Screenshot — `sudo dmidecode -s system-uuid`*

### Team Member 2 — K.A.D.Senadi (ICT/2021/109)



```
(kali@kali)-[~]  
$ sudo dmidecode -s system-uuid  
[sudo] password for kali:  
f77f4d56-b4f9-faea-fd54-37e006e71138
```

*Kali VM Screenshot — sudo dmidecode -s system-uuid*

**Team Member 3 — S.N.Mapitigama (ICT/2021/069)**

```
(kali㉿kali)-[~]  
$ sudo dmidecode -s system-uuid  
[sudo] password for kali:  
6d953be4-859f-8f43-a289-ef51708a489f
```

*Kali VM Screenshot — sudo dmidecode -s system-uuid*

**Team Member 4 — T.L.Kumarasiri (ICT/2021/150)**

```
(kali㉿kali)-[~]  
$ sudo dmidecode -s system-uuid  
[sudo] password for kali:  
52354d56-5584-71cf-a46b-1b848070968a
```

*Kali VM Screenshot — sudo dmidecode -s system-uuid*